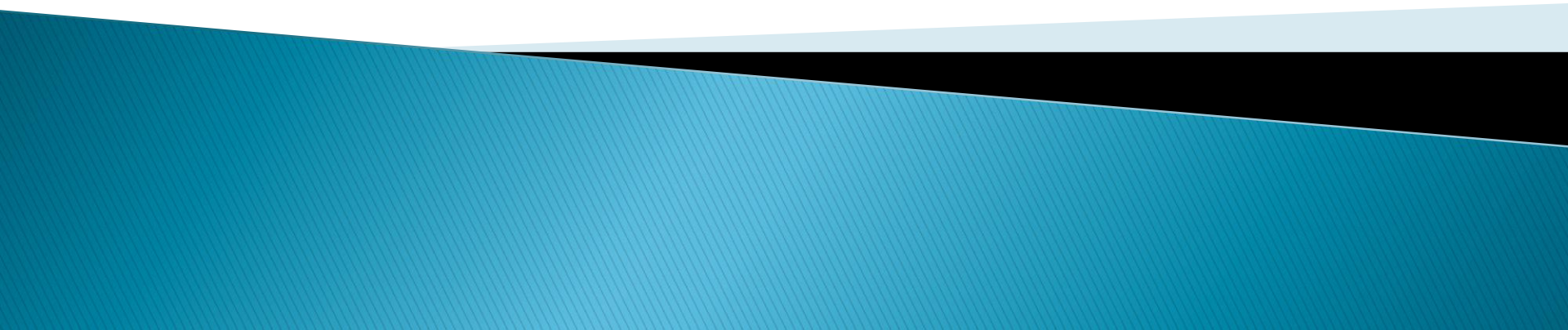


Computer Security and Cyber Law

Unit 3

Introduction to Network Security

Lecturer: Binod Chandra Shrestha



Fundamentals of Network security

- ▶ Computer networks are typically a shared resource used by many applications representing different interests.
- ▶ The Internet is particularly widely shared, being used by competing businesses, mutually antagonistic governments, and opportunistic criminals.
- ▶ Unless security measures are taken, a network conversation or a distributed application may be compromised by an adversary.
- ▶ Network security is required to protect data during transmission.

Fundamentals of Network security

- ▶ Who is vulnerable?
 - Financial institutions and banks
 - Internet service providers
 - Pharmaceutical companies
 - Government and defense agencies
 - Contractors to various government agencies
 - Multinational corporations
 - **ANYONE ON THE NETWORK**

Fundamentals of Network security

▶ Common security attacks and their countermeasures

- Finding a way into the network
 - Firewalls
- Exploiting software bugs, buffer overflows
 - Intrusion Detection Systems
- Denial of Service
 - Ingress filtering, IDS
- TCP hijacking
 - IPSec
- Packet sniffing
 - Encryption (SSH, SSL, HTTPS)
- Social problems
 - Education

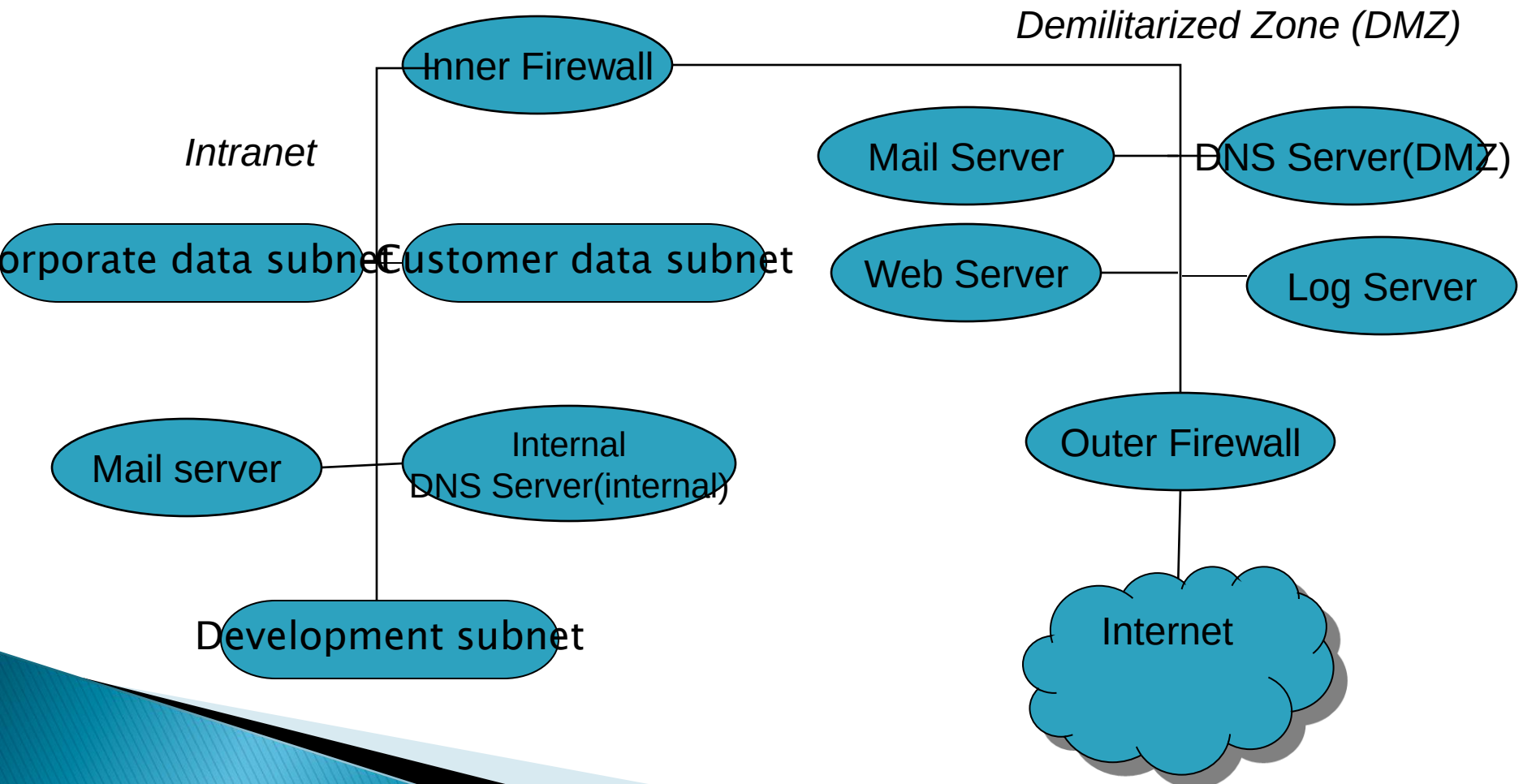
Principal Methods of Protecting Network

- ▶ **Network Encryption (Network Layer or Network Level Encryption)**
 - Network encryption (sometimes called *network layer*, or *network level encryption*) is a network security process that applies crypto services at the network transfer layer – above the data link level, but below the application level.
 - The network transfer layers are layers 3 and 4 of the Open Systems Interconnection (OSI) reference model, the layers responsible for connectivity and routing between two end points.
 - Using the existing network services and application software, network encryption is invisible to the end user and operates independently of any other encryption processes used. Data is encrypted only while in transit, existing as plaintext on the originating and receiving hosts.

Principal Methods of Protecting Network

- Network encryption is implemented through Internet Protocol Security (IPSec), a set of open Internet Engineering Task Force ([IETF](#)) standards that, used in conjunction, create a framework for private communication over [IP](#) networks.
- IPSec works through the network architecture, which means that end users and applications don't need to be altered in any way.
- Encrypted [packets](#) appear to be identical to unencrypted packets and are easily routed through any IP network.
- Network encryption products and services are offered by a number of companies, including Cisco, Motorola, and Oracle.

Network Organization



Network Organization

▶ Network Regions

- Internet
- Internal Network(Intranet)
- DMZ

▶ Network Boundaries

- Firewall
 - Filtering firewall: Based on packet headers
 - ex: preventing BackOrifice
- Proxy
 - Proxy firewall: Gives external view that hides intranet
 - ex: mail proxy

Analysis of Network Infrastructure

- ▶ Conceal the addresses of the internal network
 - Internal addresses can be real
 - Fake addresses: 10.b.c.d, 172.[16–31].c.d, 192.168.c.d
 - Network Address Translation Protocol maps internal to assigned address
- ▶ Mail Server
 - Hide internal addresses
 - Map incoming mail to “real” server
 - Additional incoming/outgoing checks

Firewalls: Configuration

▶ Outer Firewall

- What traffic allowed
 - External source: IP restrictions
 - What type of traffic: Ports (e.g., SMTP, HTTP)
- Proxy between DMZ servers and internet

▶ Internal Firewall

- Traffic restrictions: Ports, From/to IP
- Proxy between intranet and outside

DMZ

- ▶ “DMZ” stands for “demilitarized zone.”
- ▶ The *DMZ* is a portion of a network that separates a purely internal network from an external network.
- ▶ When information moves from the Internet to the internal network, confidentiality is not at issue. However, integrity is.
- ▶ The guards between the Internet and the DMZ, and between the DMZ and the internal network, must not accept messages that will cause servers to work incorrectly or to crash.
- ▶ When information moves from the internal network to the Internet, confidentiality and integrity are both at issue.

In the DMZ

► DMZ Mail Server

- performs address and content checking on all electronic mail messages
- When it receives a letter from the Internet, it performs the following Steps
 - reassembles the message into a set of headers, a letter, and any attachments
 - scans the letter and attachments for any computer virus or malicious logic.
 - Restore the attachments to transmit
 - Rescan it for any violation of SMTP specification
 - Scans the recipient address lines.
 - Addresses that directed the mail to the drib are rewritten to direct the mail to the internal mail server

In the DMZ

▶ DMZ Mail Server

- When it receives a outgoing letter from the internal mail server
 - Steps 1 and 2 are the same
 - In step 3 the mail proxy scans the header lines.
 - All lines that mention internal hosts are rewritten to identify the host as “drib.org”, the name of the outside firewall.

In the DMZ

- ▶ DMZ WWW Server
 - Identifies itself as “www.drib.org” and uses IP address of the outside firewall
- ▶ DMZ DNS Server
 - It contain entries for
 - DMZ mail, Web and log hosts
 - Internal trusted administrative host
 - Outer firewall
 - Inner firewall
- ▶ DMZ Log Server

Firewalls

- ▶ *A firewall is a host that mediates access to a network, allowing and disallowing certain types of access on the basis of a configured security policy.*
- ▶ A firewall accepts or rejects messages on the basis of external information, such as destination addresses or ports, rather than on the basis of the contents of the message.
- ▶ *A filtering firewall performs access control on the basis of attributes of the packet headers, such as destination addresses, source addresses, and options.*

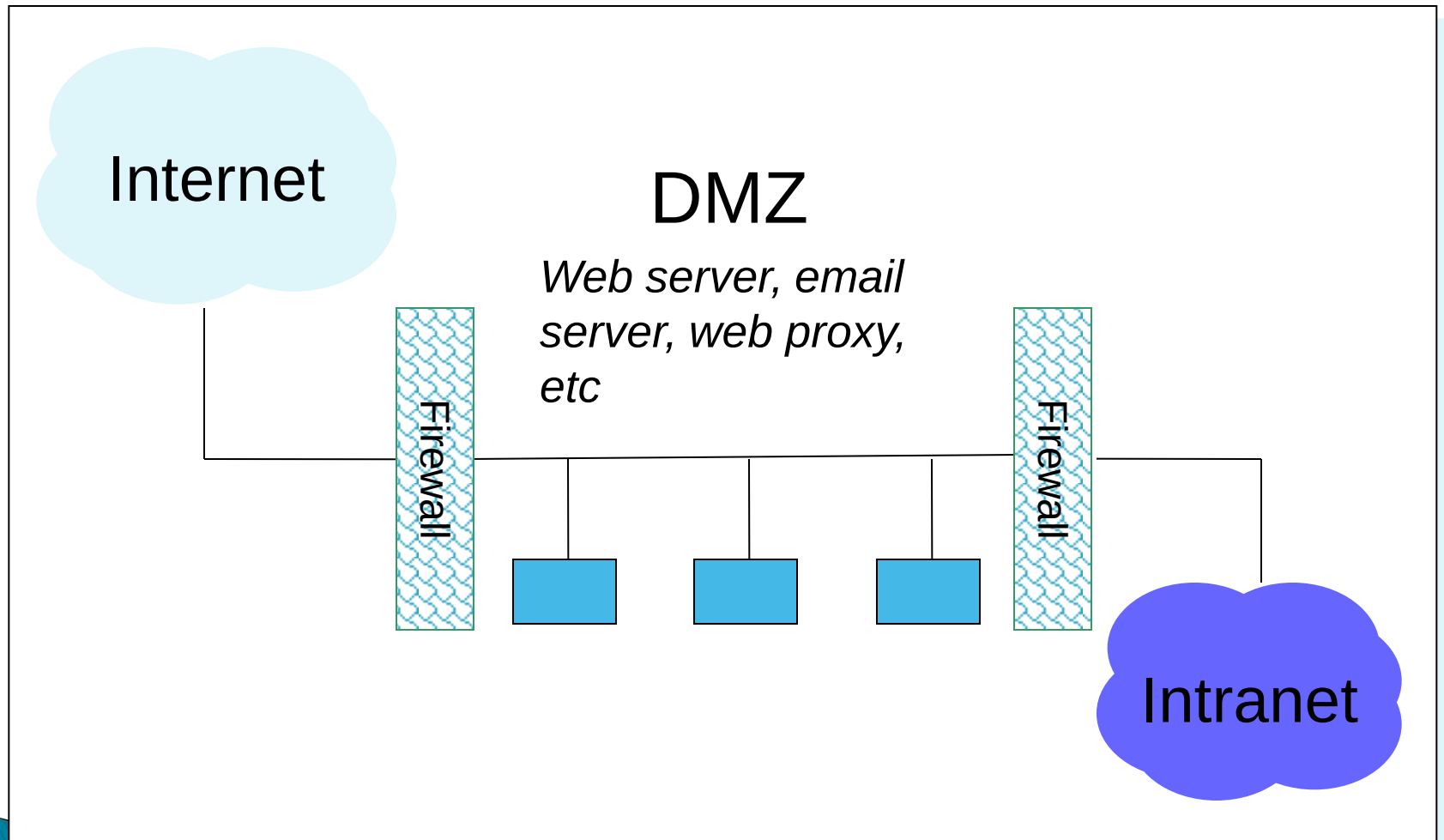
Firewalls

- ▶ Basic problem – many network applications and protocols have security problems that are fixed over time
 - Difficult for users to keep up with changes and keep host secure
 - Solution
 - Administrators limit access to end hosts by using a firewall
 - Firewall is kept up-to-date by administrators

Firewalls

- ▶ A firewall is like a castle with a drawbridge
 - Only one point of access into the network
 - This can be good or bad
- ▶ Can be hardware or software
 - Ex. Some routers come with firewall functionality
 - ipfw, ipchains, pf on Unix systems, Windows XP and Mac OS X have built in firewalls

Firewalls



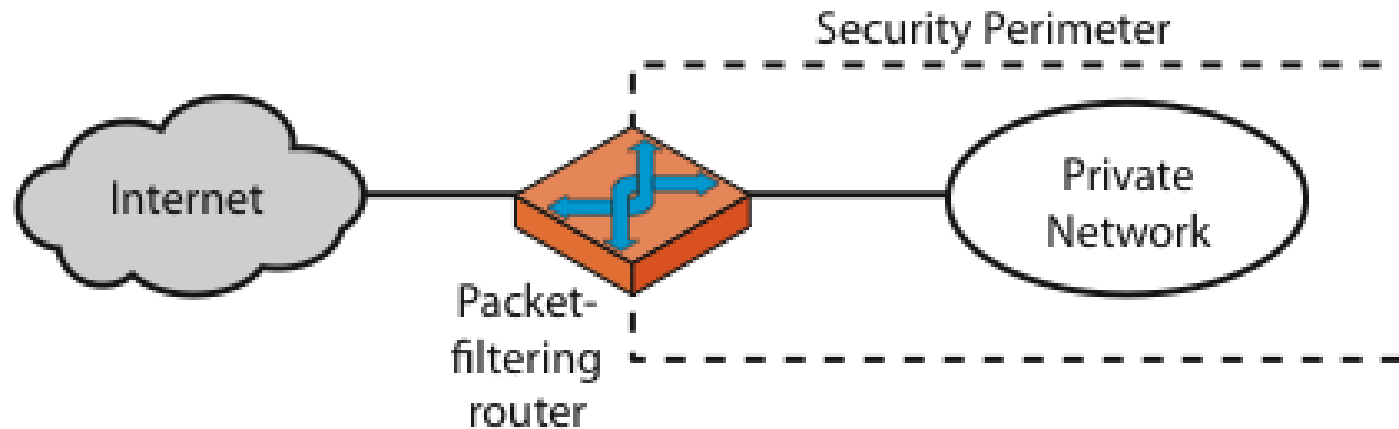
Proxy

- ▶ *A proxy is an intermediate agent or server that acts on behalf of an endpoint without allowing a direct connection between the two endpoints.*
- ▶ *A proxy (or applications level) firewall uses proxies to perform access control. A proxy firewall can base access control on the contents of packets and messages, as well as on attributes of the packet headers.*
- ▶ A proxy firewall adds to a filtering firewall the ability to base access on content, either at the packet level or at a higher level of abstraction.

Types of Firewalls

- ▶ Packet Filtering,
- ▶ State–full Packet Filtering
- ▶ Circuit Level Gateway,
- ▶ Application level/proxy

Firewalls – Packet Filters



(a) Packet-filtering router

Firewalls – Packet Filters

- ▶ Simplest of components
- ▶ Uses transport-layer information only
 - IP Source Address, Destination Address
 - Protocol/Next Header (TCP, UDP, ICMP, etc)
 - TCP or UDP source & destination ports
 - TCP Flags (SYN, ACK, FIN, RST, PSH, etc)
 - ICMP message type
- ▶ Examples
 - DNS uses port 53
 - No incoming port 53 packets except known trusted servers

Usage of Packet Filters

- ▶ Filtering with incoming or outgoing interfaces
 - E.g., Ingress filtering of spoofed IP addresses
 - Egress filtering
- ▶ Permits or denies certain services
 - Requires intimate knowledge of TCP and UDP port utilization on a number of operating systems

How to Configure a Packet Filter

- ▶ Start with a security policy
- ▶ Specify allowable packets in terms of logical expressions on packet fields
- ▶ Rewrite expressions in syntax supported by your vendor
- ▶ General rules – least privilege
 - All that is not expressly permitted is prohibited
 - If you do not need it, eliminate it

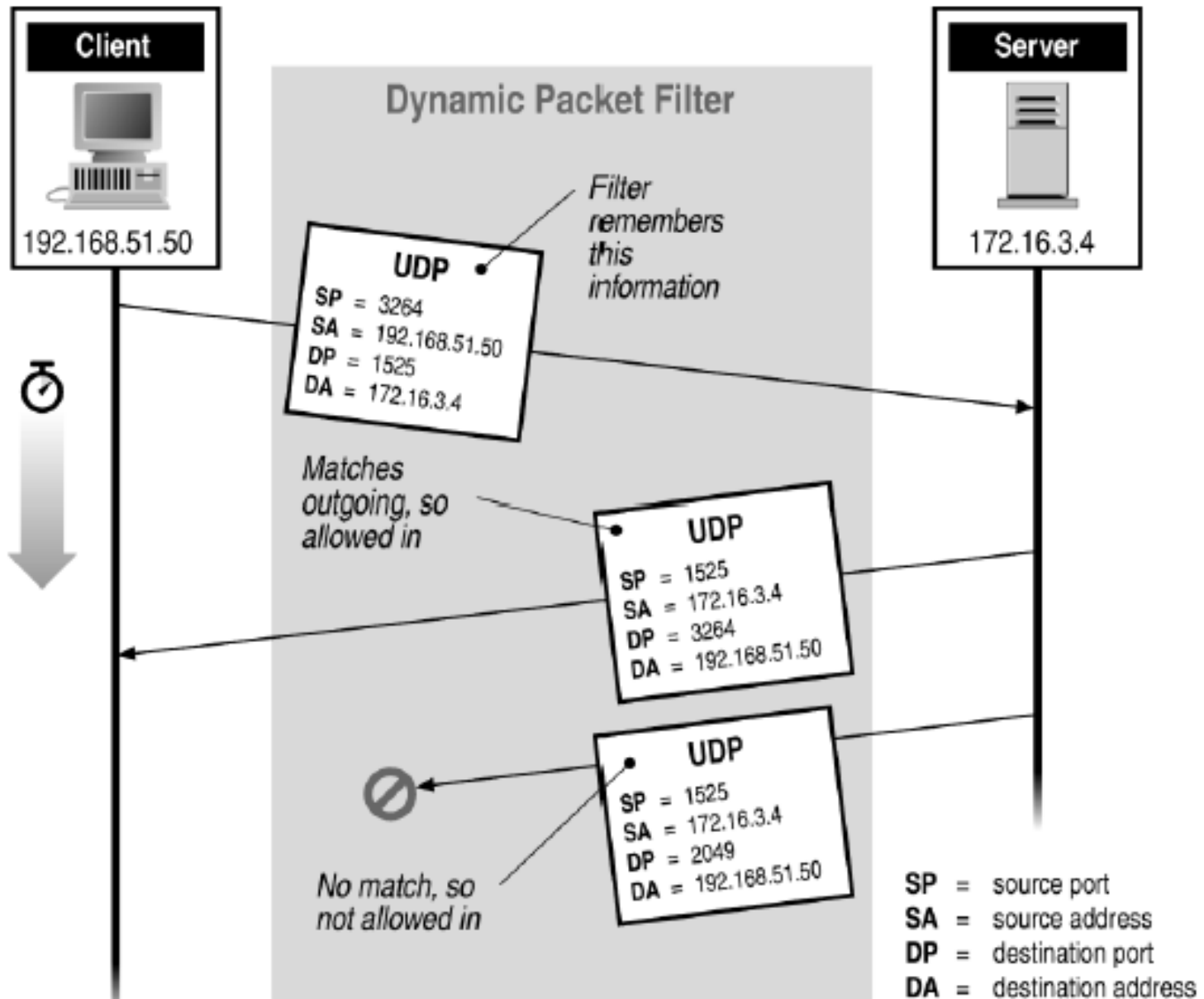
Security & Performance of Packet Filters

- ▶ Tiny fragment attacks
 - Split TCP header info over several tiny packets
 - Either discard or reassemble before check
- ▶ Degradation depends on number of rules applied at any point
- ▶ Order rules so that most common traffic is dealt with first
- ▶ Correctness is more important than speed

Firewalls – Stateful Packet Filters

- ▶ Traditional packet filters do not examine transport layer context
 - ie matching return packets with outgoing flow
- ▶ Stateful packet filters address this need
- ▶ They examine each IP packet in context
 - Keep track of client–server sessions
 - Check each packet validly belongs to one
- ▶ Hence are better able to detect bogus packets out of context

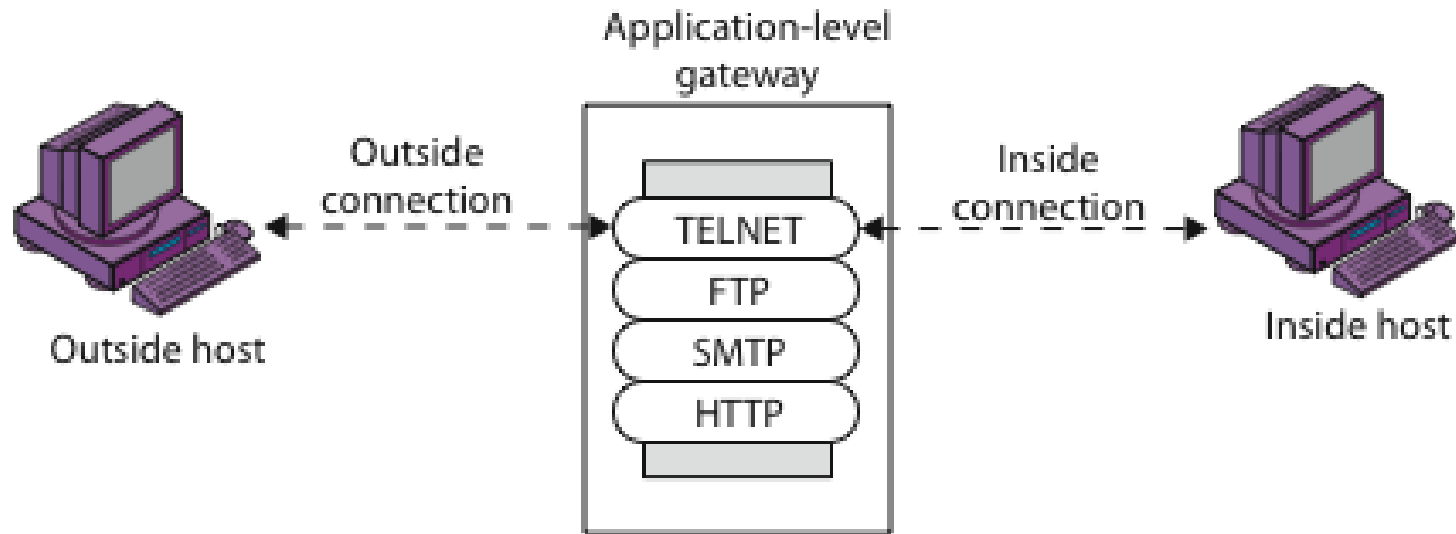
Stateful Filtering



Firewall Gateways

- ▶ Firewall runs set of proxy programs
 - Proxies filter incoming, outgoing packets
 - All incoming traffic directed to firewall
 - All outgoing traffic appears to come from firewall
- ▶ Policy embedded in proxy programs
- ▶ Two kinds of proxies
 - Application-level gateways/proxies
 - Tailored to http, ftp, smtp, etc.
 - Circuit-level gateways/proxies
 - Working on TCP level

Firewalls – Application Level Gateway (or Proxy)

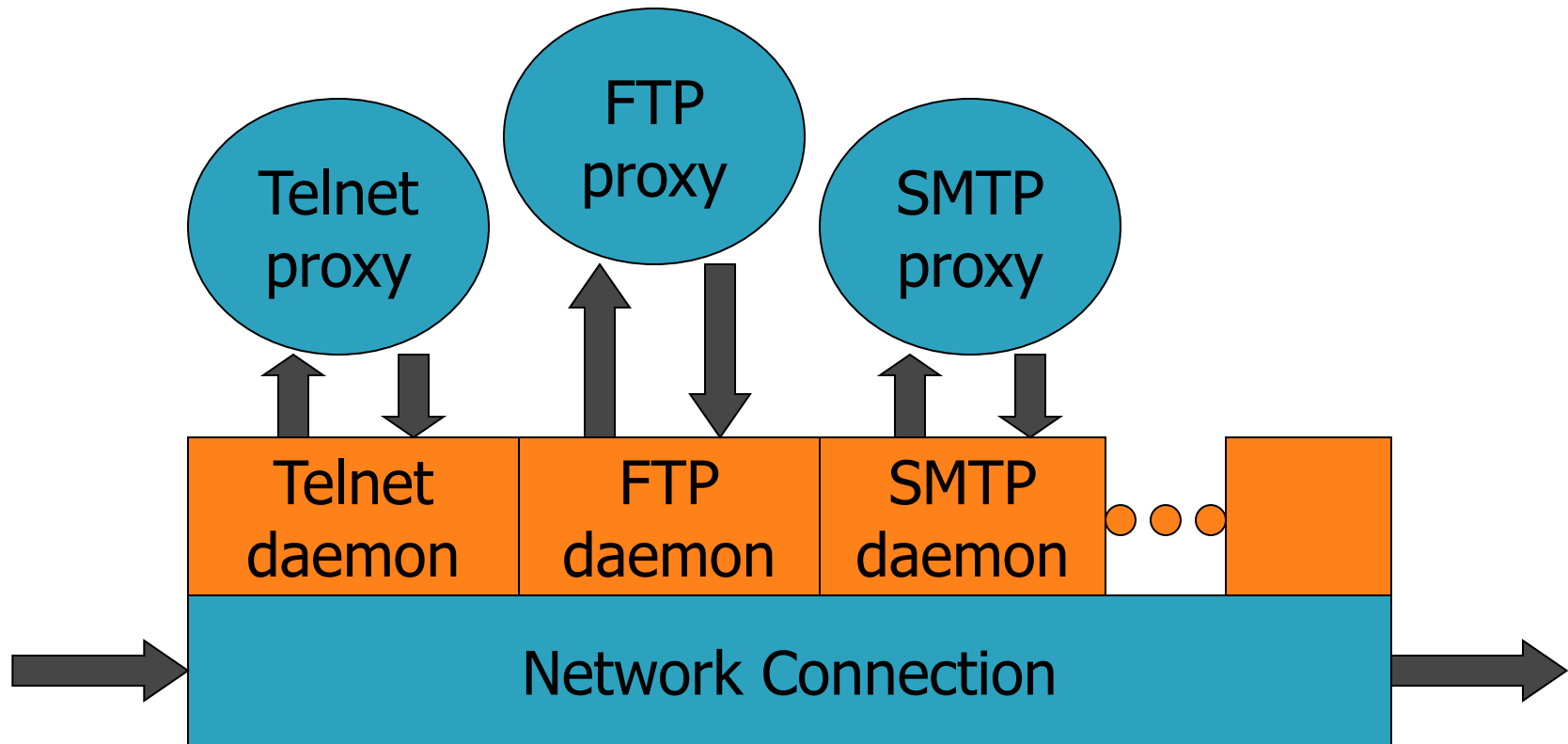


(b) Application-level gateway

Application-Level Filtering

- ▶ Has full access to protocol
 - user requests service from proxy
 - proxy validates request as legal
 - then actions request and returns result to user
- ▶ Need separate proxies for each service
 - E.g., SMTP (E-Mail)
 - NNTP (Net news)
 - DNS (Domain Name System)
 - NTP (Network Time Protocol)
 - custom services generally not supported

App-level Firewall Architecture



Daemon spawns proxy when communication detected

Enforce policy for specific protocols

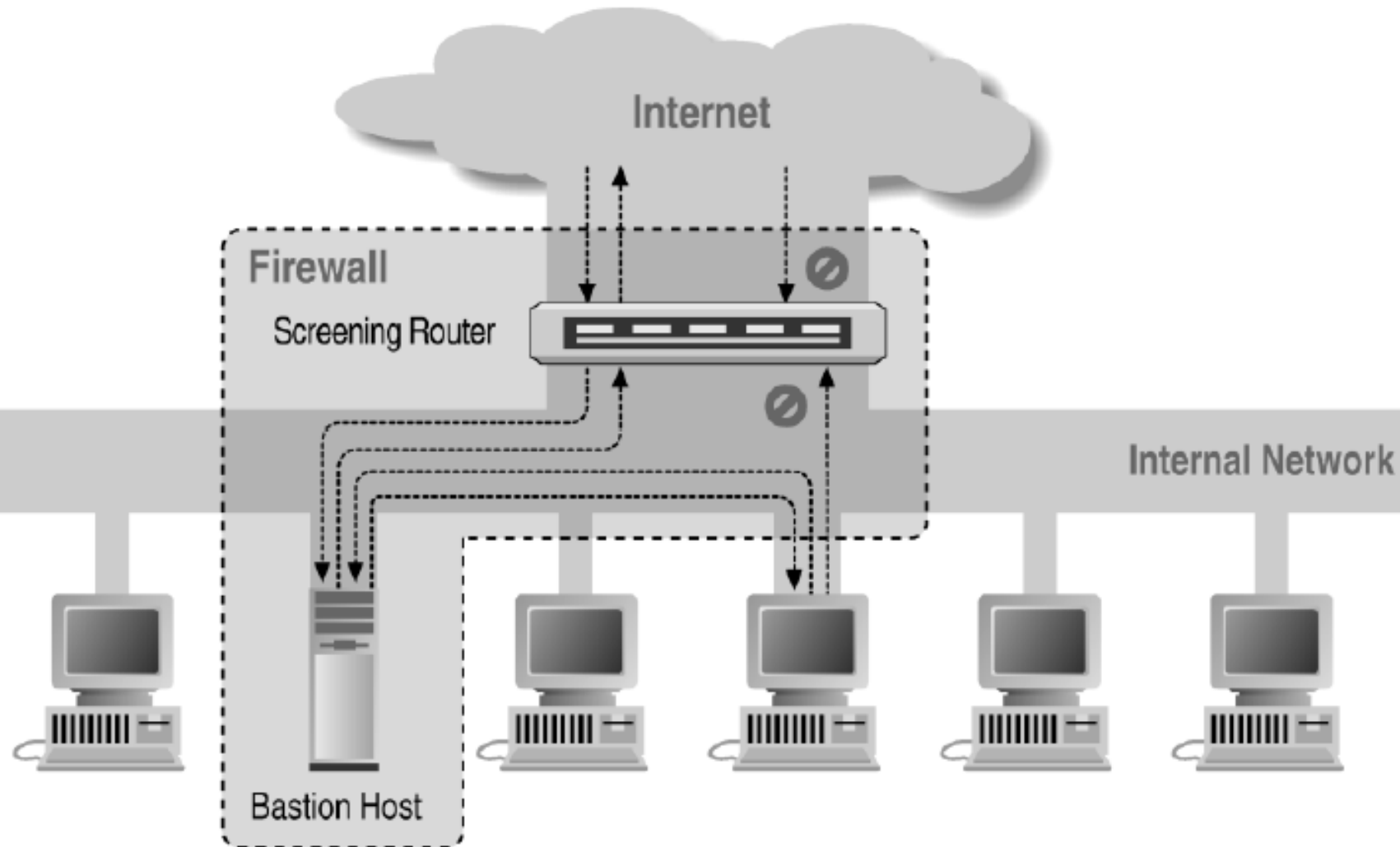
- ▶ E.g., Virus scanning for SMTP
 - Need to understand MIME, encoding, Zip archives

Where to Deploy App-level Firewall

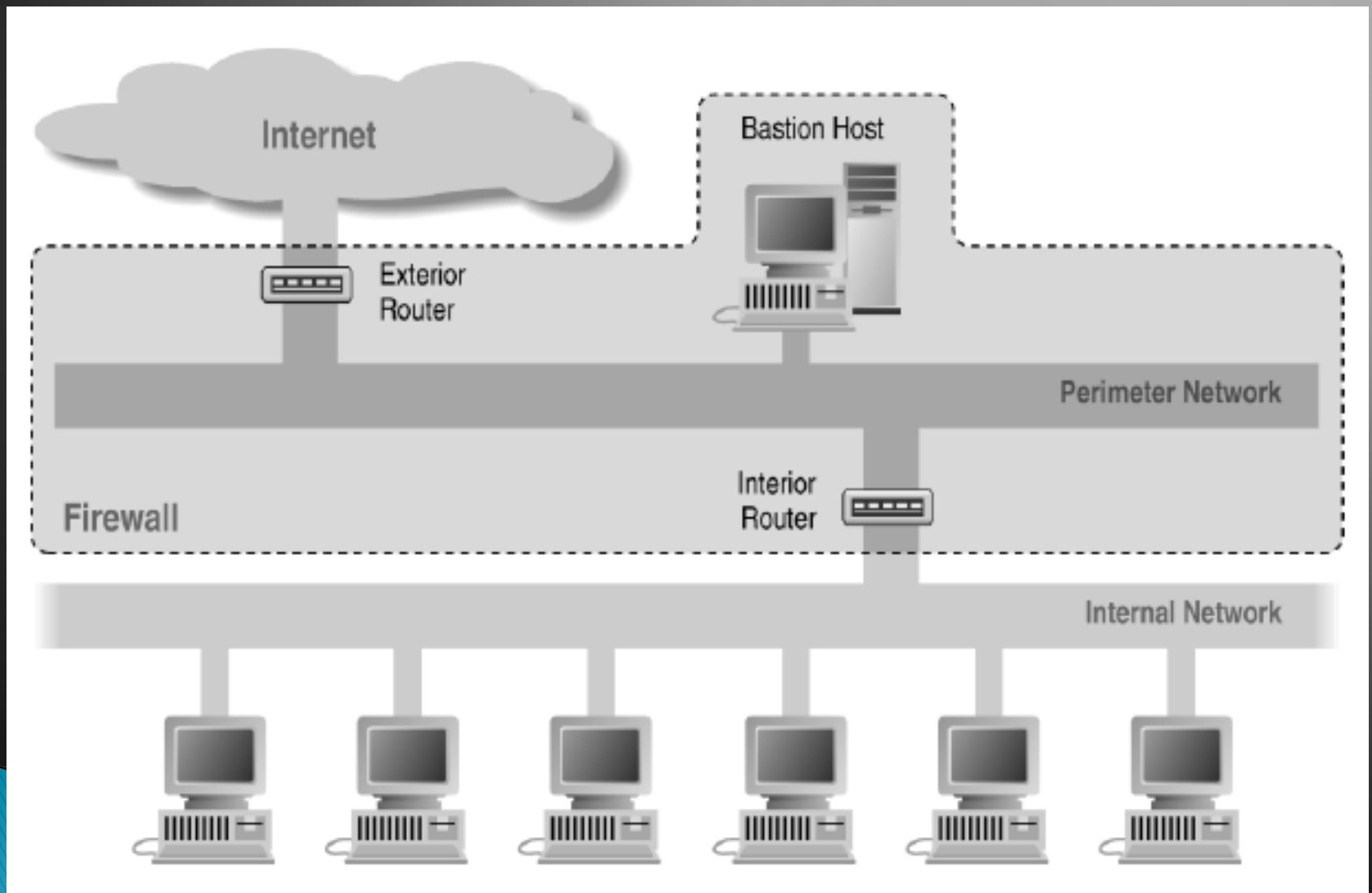
Bastion Host: highly secure host system

- ▶ Potentially exposed to "hostile" elements
- ▶ Hence is secured to withstand this
 - Disable all non-required services; keep it simple
- ▶ Runs circuit / application level gateways
 - Install/modify services you want
- ▶ Or provides externally accessible services

Screened Host Architecture



Screened Subnet Using Two Routers



Firewalls Aren't Perfect?

- ▶ Useless against attacks from the inside
 - Evildoer exists on inside
 - Malicious code is executed on an internal machine
- ▶ Organizations with greater insider threat
 - Banks and Military
- ▶ Cannot protect against transfer of all virus infected programs or files
 - because of huge range of O/S & file types

What Security Problem?

Today's Internet is primarily comprised of :

- ▶ Public
- ▶ Un-trusted
- ▶ Unreliable IP networks

Because of this inherent lack of security, the Internet is subject to various types of threats...

Internet Threats

- ▶ Data integrity

The contents of a packet can be accidentally or deliberately modified.

- ▶ Identity spoofing

The origin of an IP packet can be forged.

- ▶ Anti-reply attacks

Unauthorized data can be retransmitted.

- ▶ Loss of privacy

The contents of a packet can be examined in transit.

Understanding TCP/IP

OSI Reference Model

Application Layer
Presentation Layer
Session Layer
Transport Layer
Network Layer
Logical Link Layer
Physical Layer

Application
HTTP
SMTP
FTP
DNS
FTP
SNMP
NFS
TCP, UDP
IP
Device Driver
Network Adapter

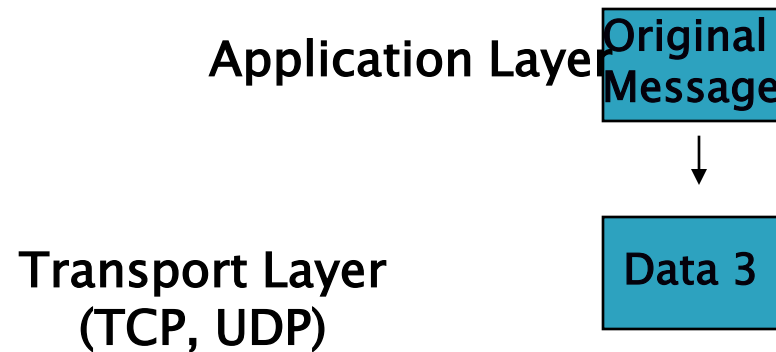
Understanding TCP/IP

Encapsulation of Data for Network Delivery

Application Layer 

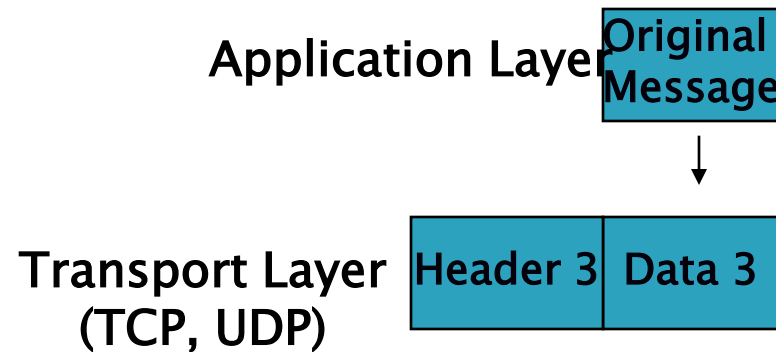
Understanding TCP/IP

Encapsulation of Data for Network Delivery



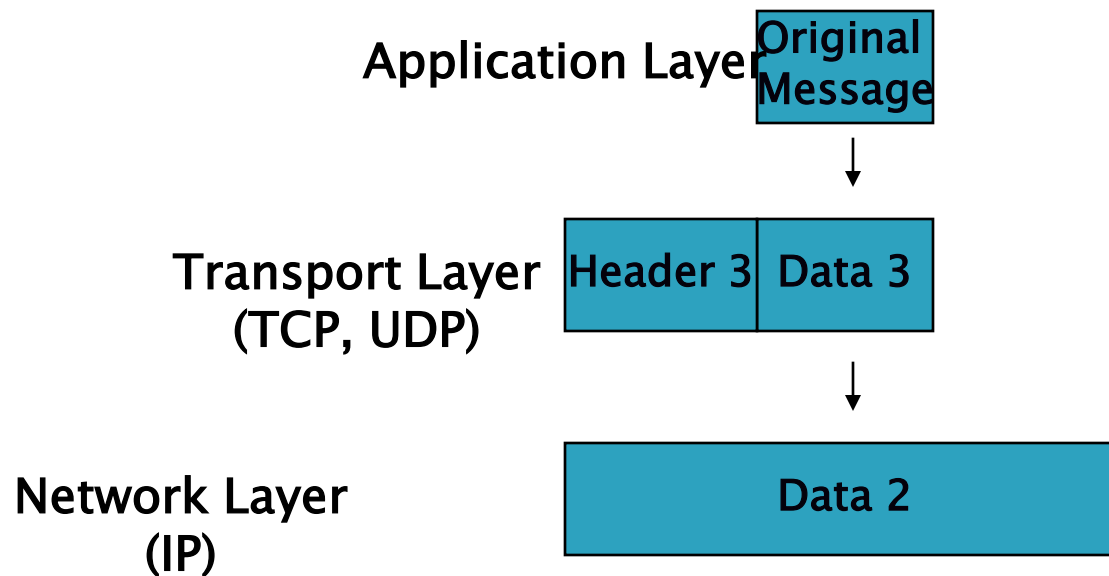
Understanding TCP/IP

Encapsulation of Data for Network Delivery



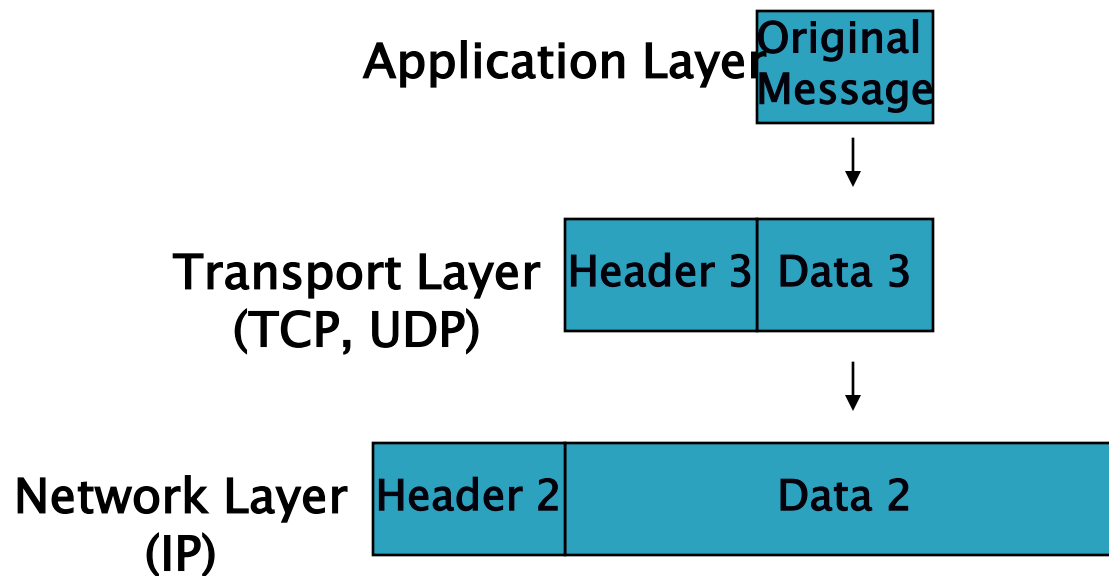
Understanding TCP/IP

Encapsulation of Data for Network Delivery



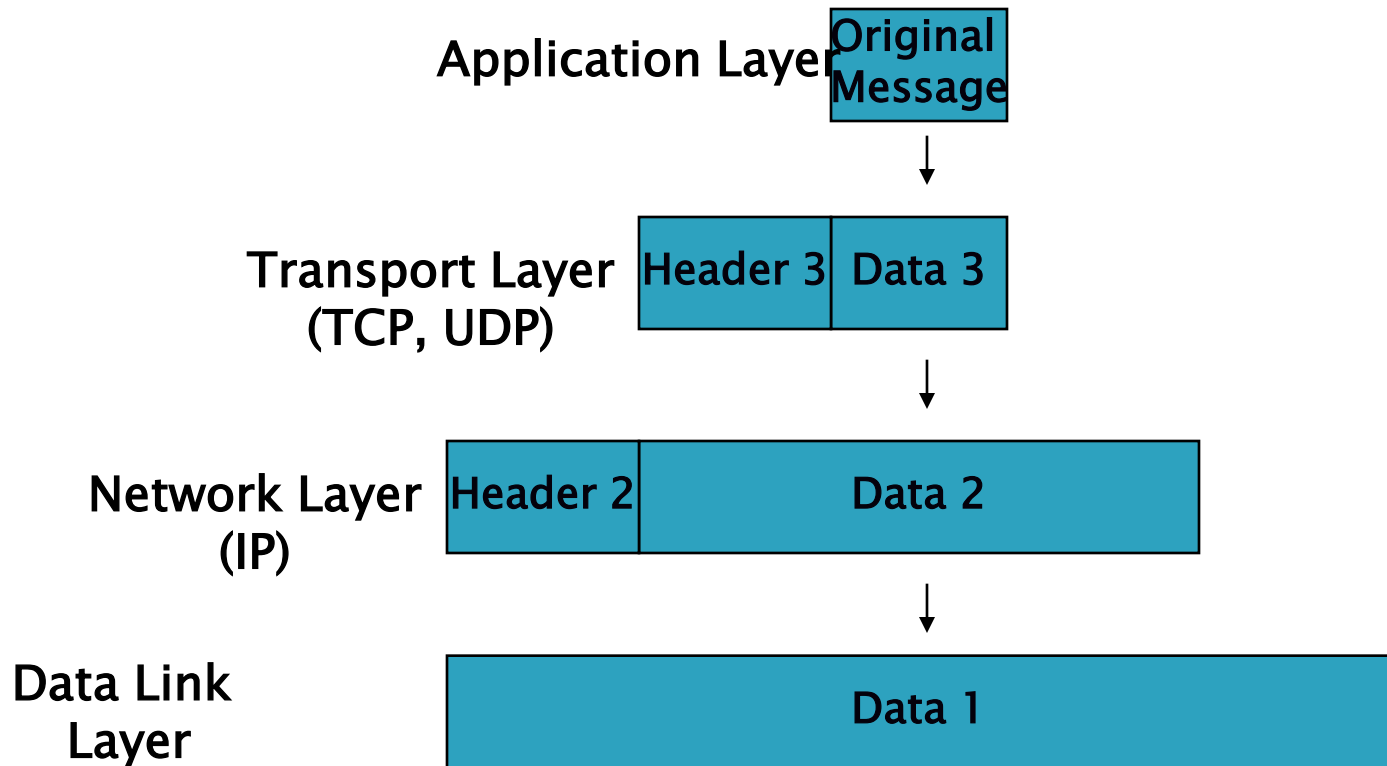
Understanding TCP/IP

Encapsulation of Data for Network Delivery



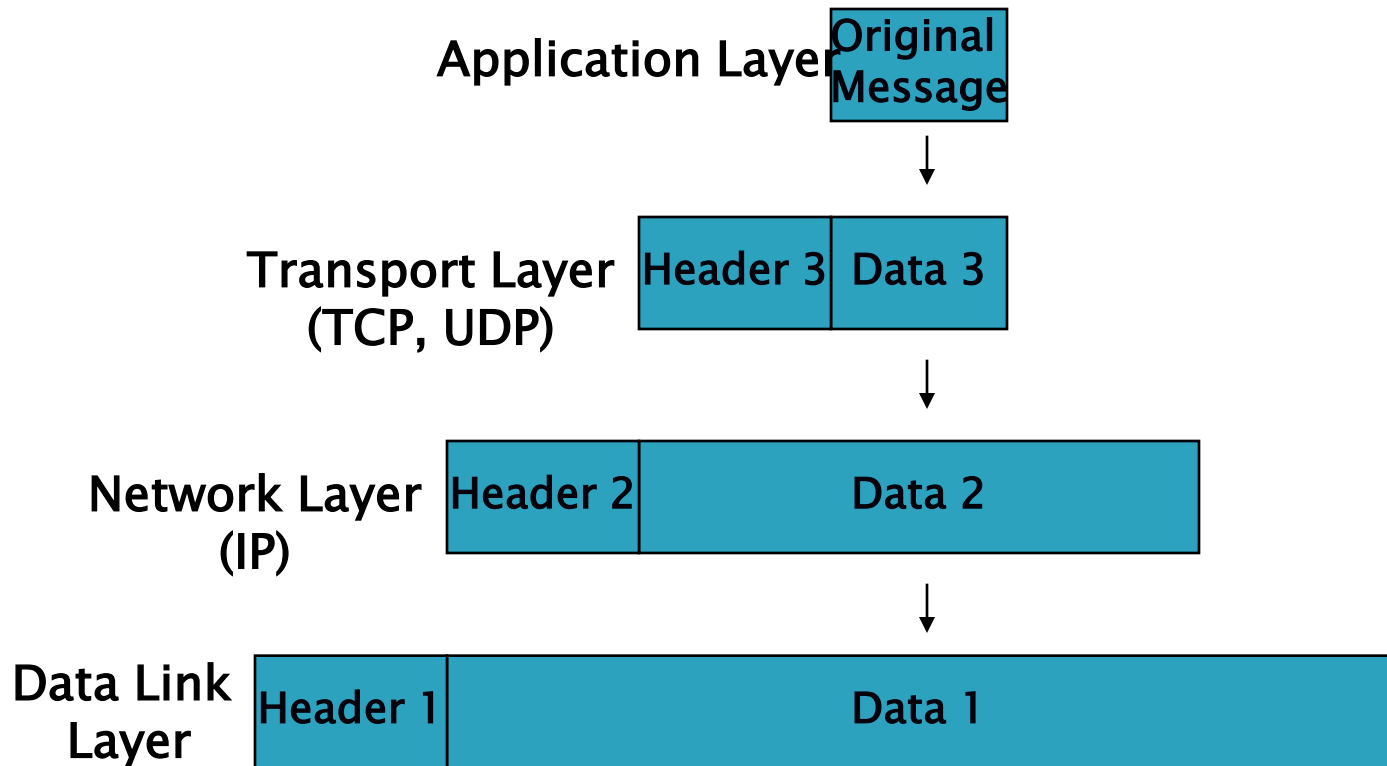
Understanding TCP/IP

Encapsulation of Data for Network Delivery



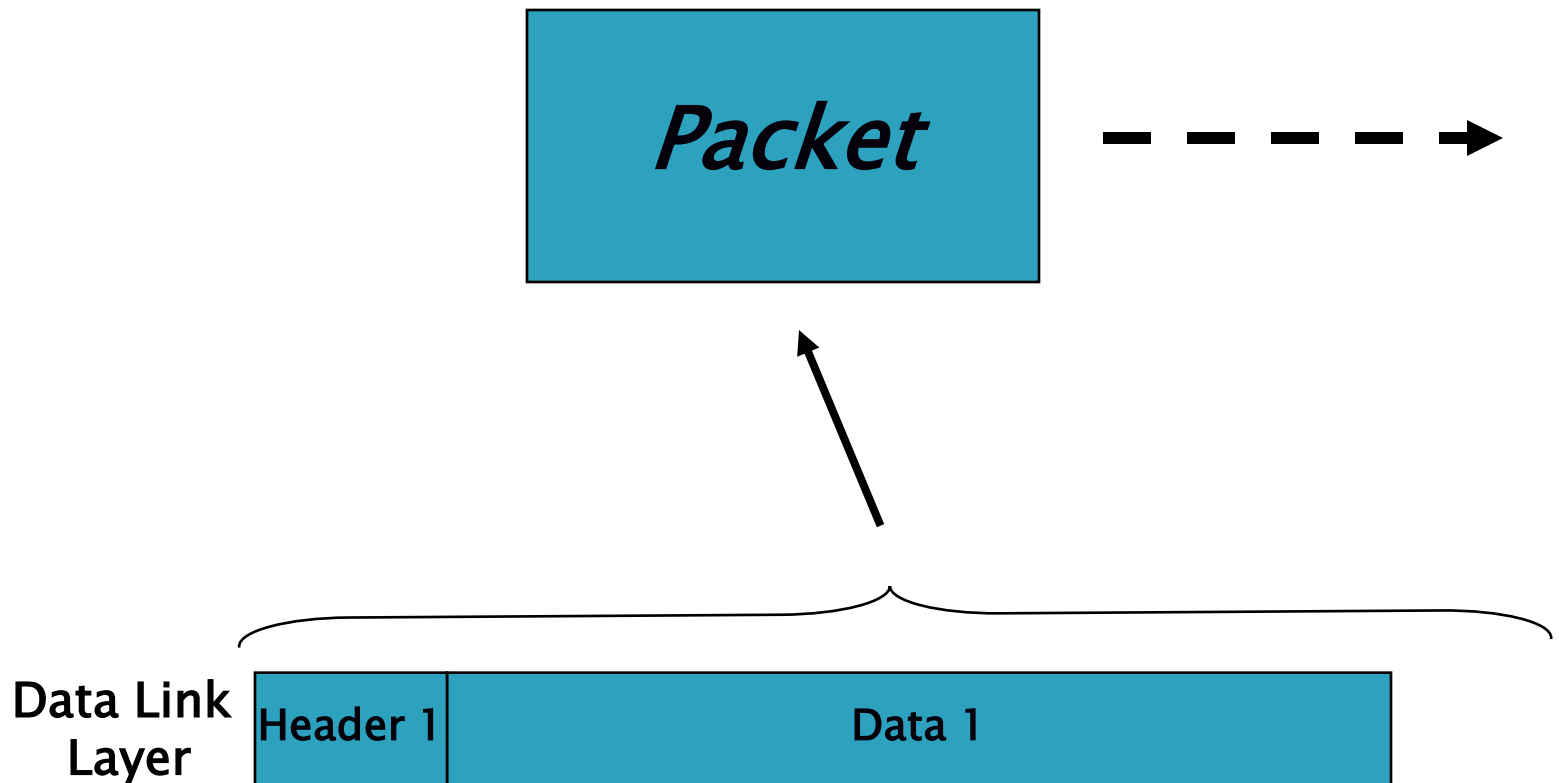
Understanding TCP/IP

Encapsulation of Data for Network Delivery



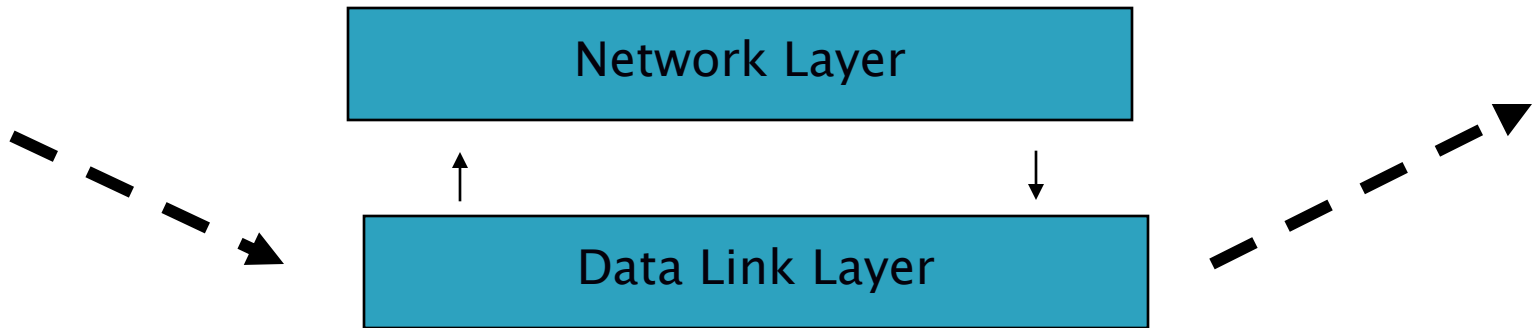
Understanding TCP/IP

Packet Sent by Host A



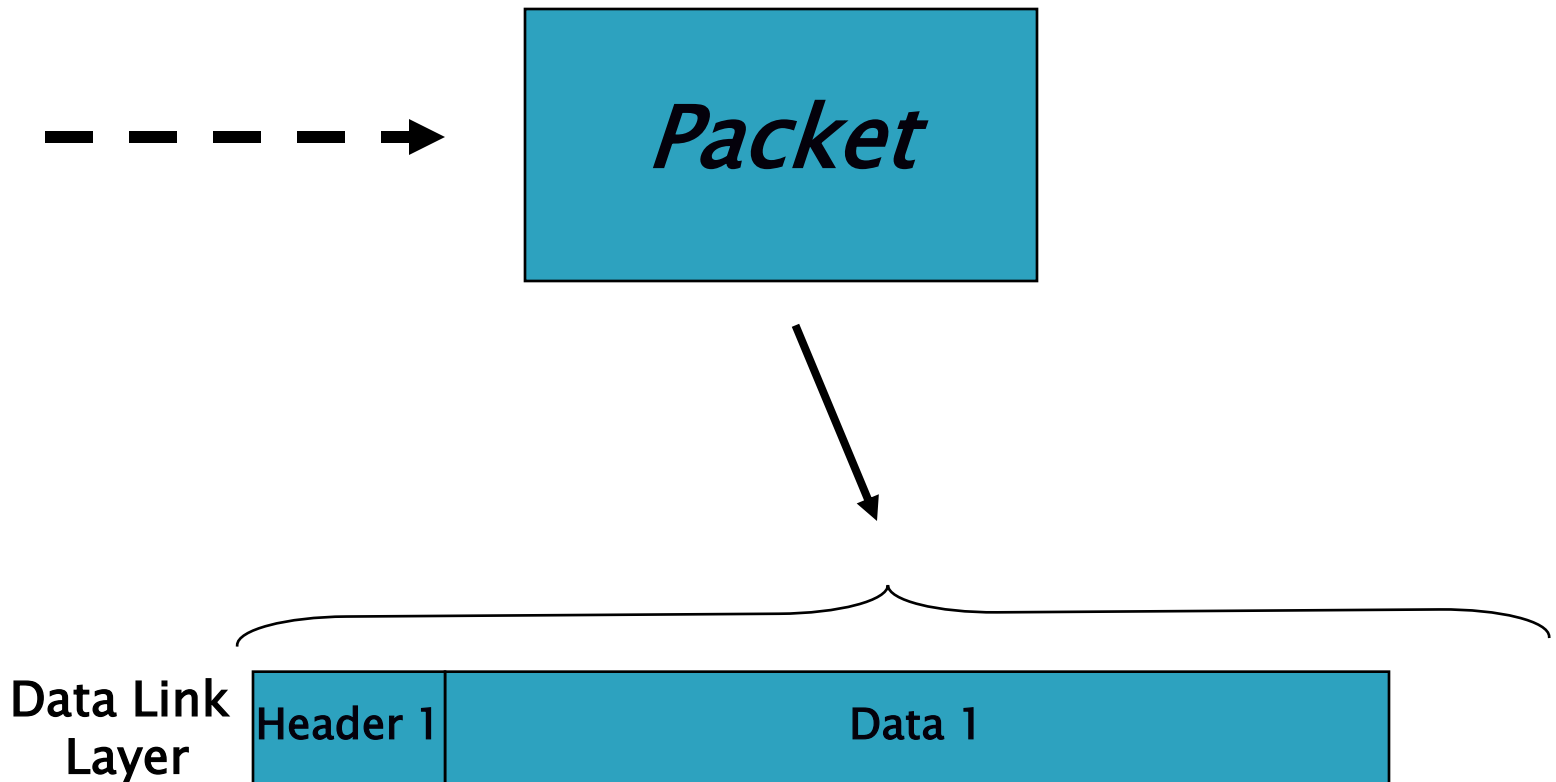
Understanding TCP/IP

Packet Received by intermediary Router



Understanding TCP/IP

Packet Received by Host B



Understanding TCP/IP

De-capsulation of Data from Network Delivery

Data Link
Layer



Understanding TCP/IP

De-capsulation of Data from Network Delivery

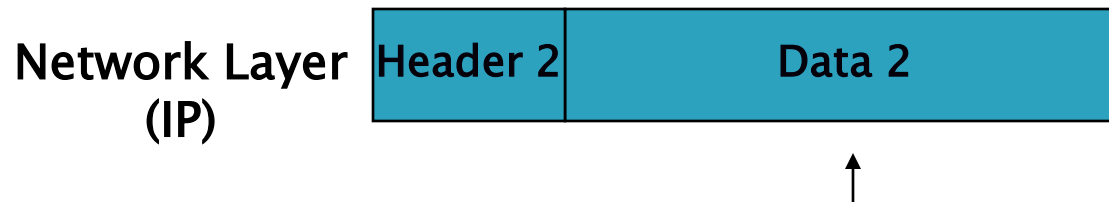
Data Link
Layer



Data 1

Understanding TCP/IP

De-capsulation of Data from Network Delivery



Understanding TCP/IP

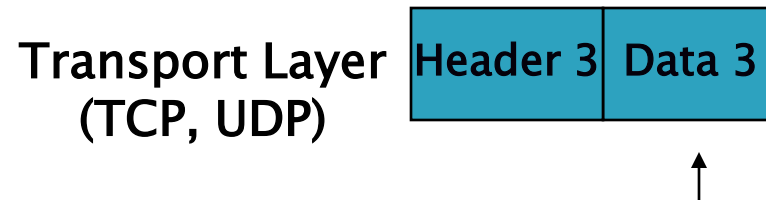
De-capsulation of Data from Network Delivery

Network Layer
(IP)



Understanding TCP/IP

De-capsulation of Data from Network Delivery



Understanding TCP/IP

De-capsulation of Data from Network Delivery

Transport Layer
(TCP, UDP)

Data 3

Understanding TCP/IP

De-capsulation of Data from Network Delivery



Understanding TCP/IP

De-capsulation of Data from Network Delivery

Application Layer 

Security at What Level?

Application Layer	PGP, Kerberos, SSH, etc.
Transport Layer	Transport Layer Security (TLS)
Network Layer	IP Security
Data Link Layer	Hardware encryption

Security at Application Layer

(PGP, Kerberos, SSH, etc.)

- ▶ Implemented in end-hosts
- ▶ Advantages
 - Extend application without involving operating system.
 - Application can understand the data and can provide the appropriate security.
- ▶ Disadvantages
 - Security mechanisms have to be designed independently of each application.

Security at Transport Layer

Transport Layer Security (TLS)

- ▶ Implemented in end-hosts
- ▶ Advantages
 - Existing applications get security seamlessly
- ▶ Disadvantages
 - Protocol specific

Security at Network Layer

IP Security (IPSec)

▶ Advantages

- Provides seamless security to application and transport layers (ULPs).
- Allows per flow or per connection security and thus allows for very fine-grained security control.

▶ Disadvantages

- More difficult to exercise on a per user basis on a multi-user machine.

Security at Data Link Layer

- ▶ (Hardware encryption)
- ▶ Need a dedicated link between host/routers.
- ▶ Advantages
 - Speed.
- ▶ Disadvantages
 - Not scalable.
 - Need dedicated links.

IP Security (IPSec)

- ▶ IPSec is a framework of open standards developed by the Internet Engineering Task Force (IETF).

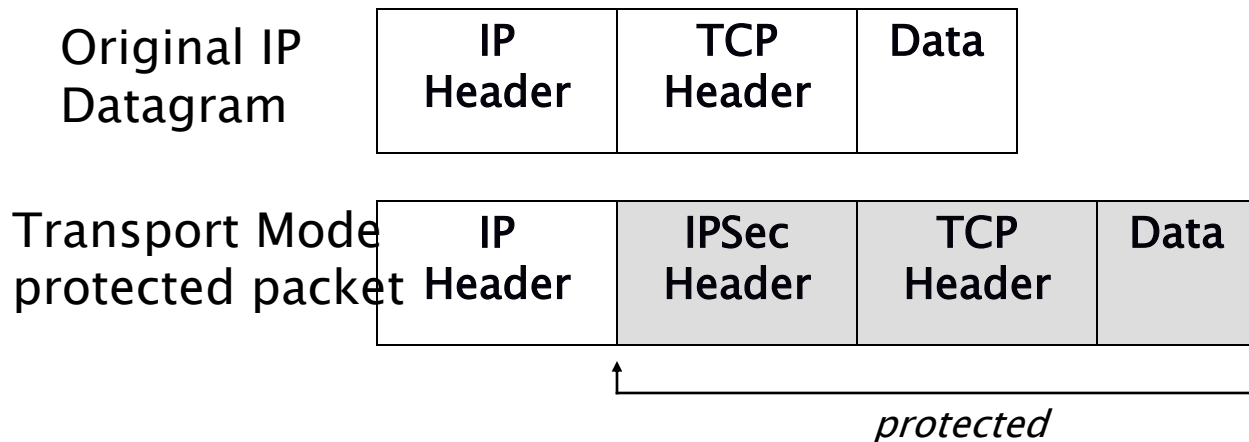
Creates secure, authenticated, reliable communications over IP networks

IPSec Security Services

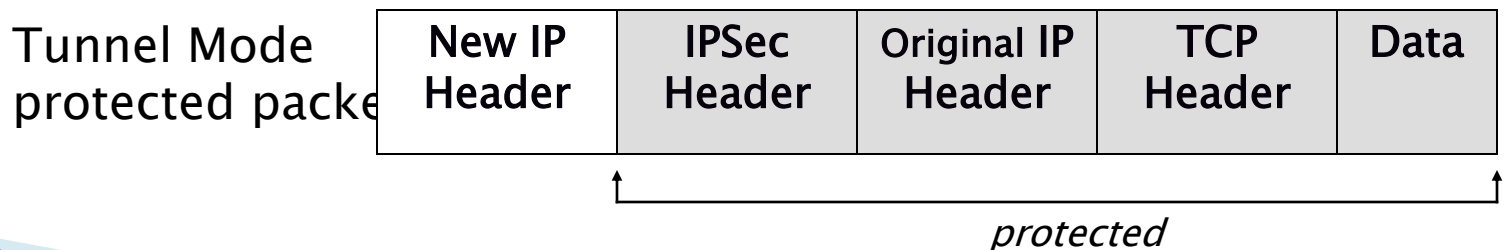
- ▶ **Connectionless integrity**
Assurance that received traffic has not been modified. Integrity includes anti-reply defenses.
- ▶ **Data origin authentication**
Assurance that traffic is sent by legitimate party or parties.
- ▶ **Confidentiality (encryption)**
Assurance that user's traffic is not examined by non-authorized parties.
- ▶ **Access control**
Prevention of unauthorized use of a resource.

IPSec Modes of Operation

- ▶ Transport Mode: protect the upper layer protocols

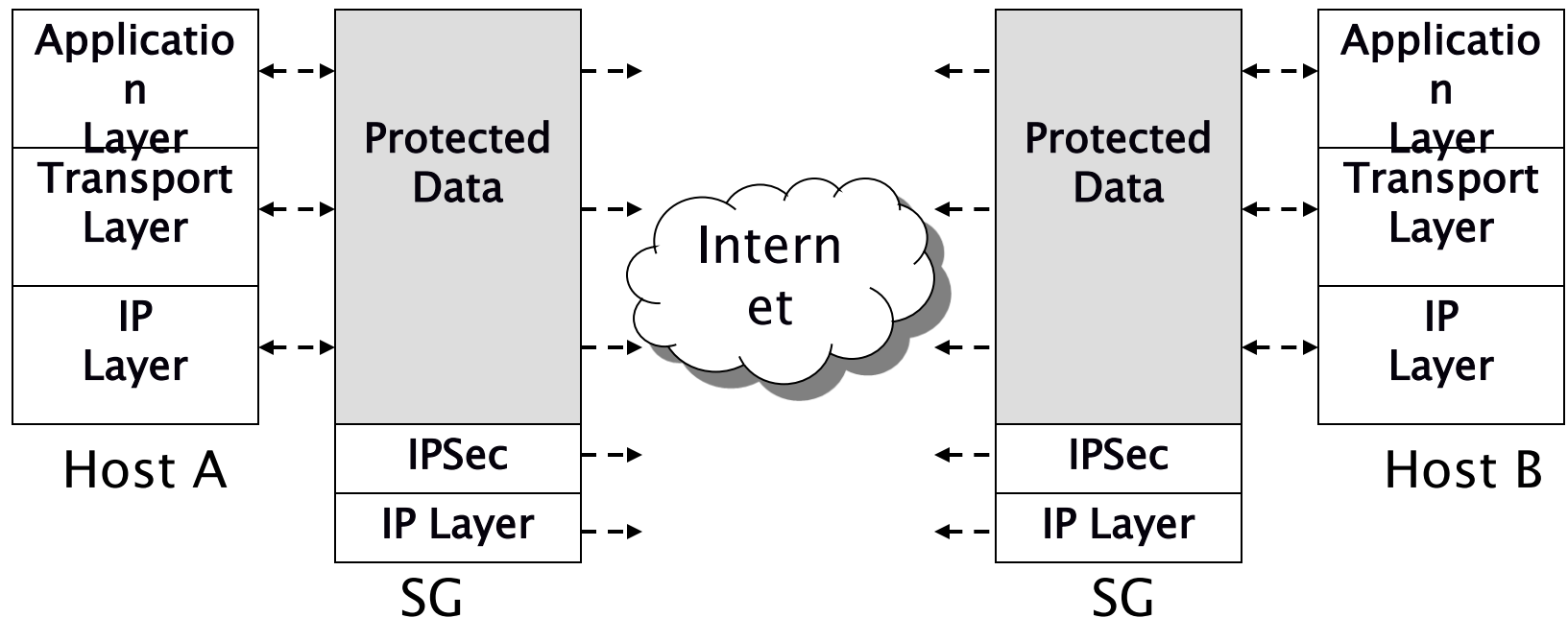


- ◆ Tunnel Mode: protect the entire IP payload



Tunnel Mode

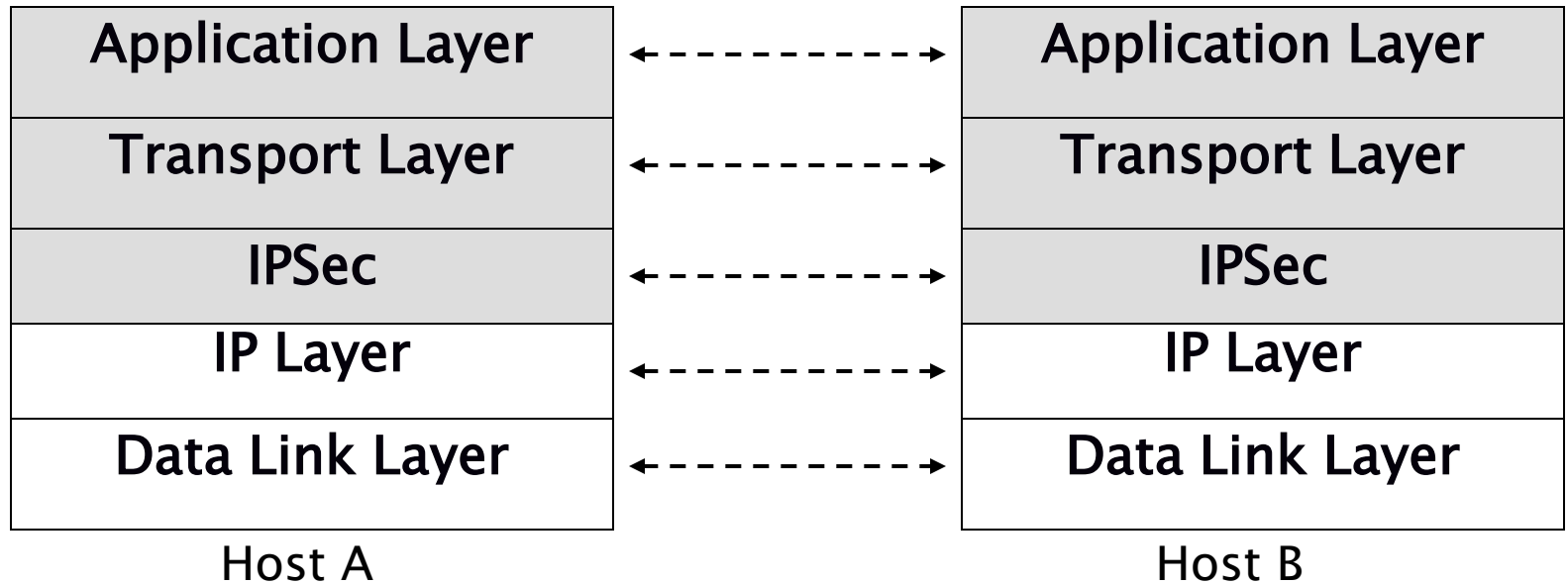
- ▶ Host-to-Network, Network-to-Network



SG = Security Gateway

Transport Mode

► Host-to-Host



IPSec Security Protocols

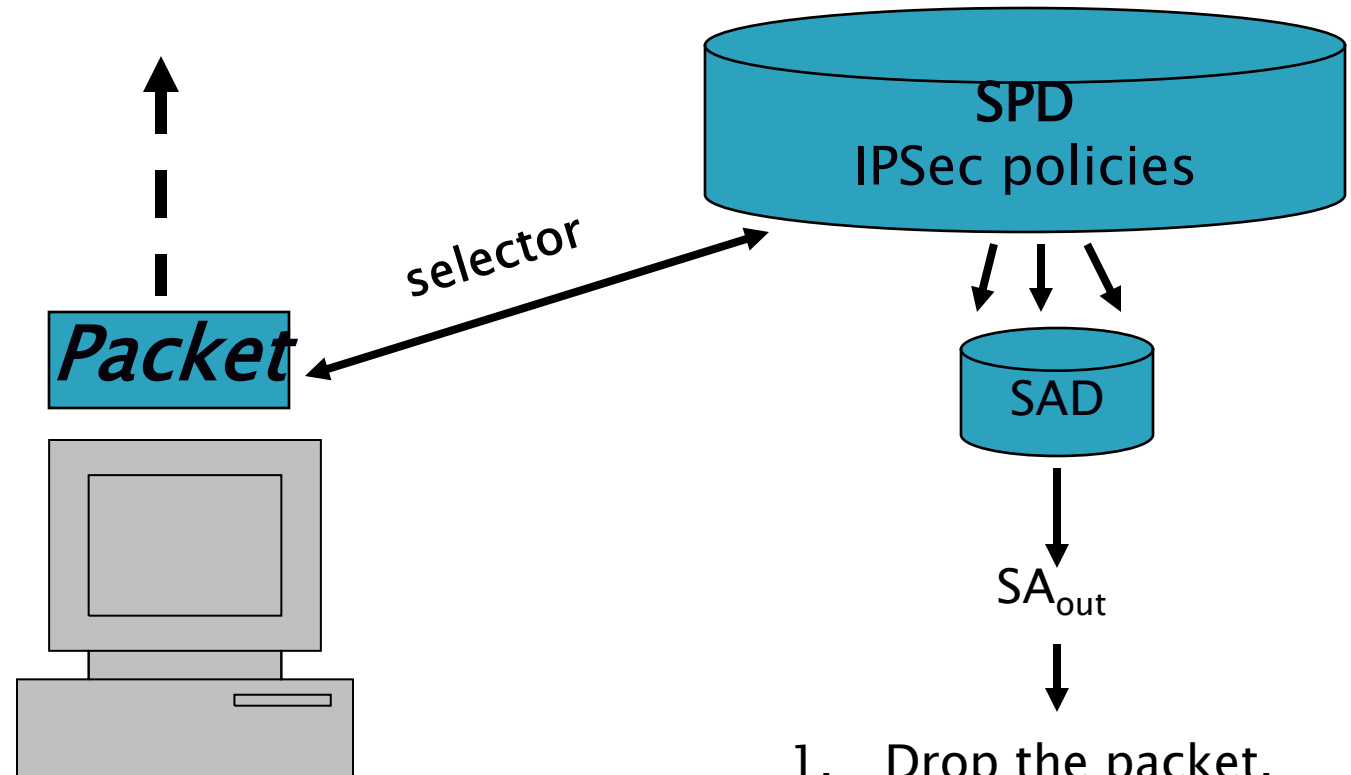
- ▶ Authentication Header (AH) provides:
 - Connectionless integrity
 - Data origin authentication
 - Protection against replay attacks
- ▶ Encapsulating Security Payload (ESP) provides:
 - Confidentiality (encryption)
 - Connectionless integrity
 - Data origin authentication
 - Protection against reply attacks
- ▶ Both protocols may be used alone or applied in combination with each other.

Outbound/Inbound IPSec Processing

- ▶ The inbound and the outbound IPSec processing are completely independent.



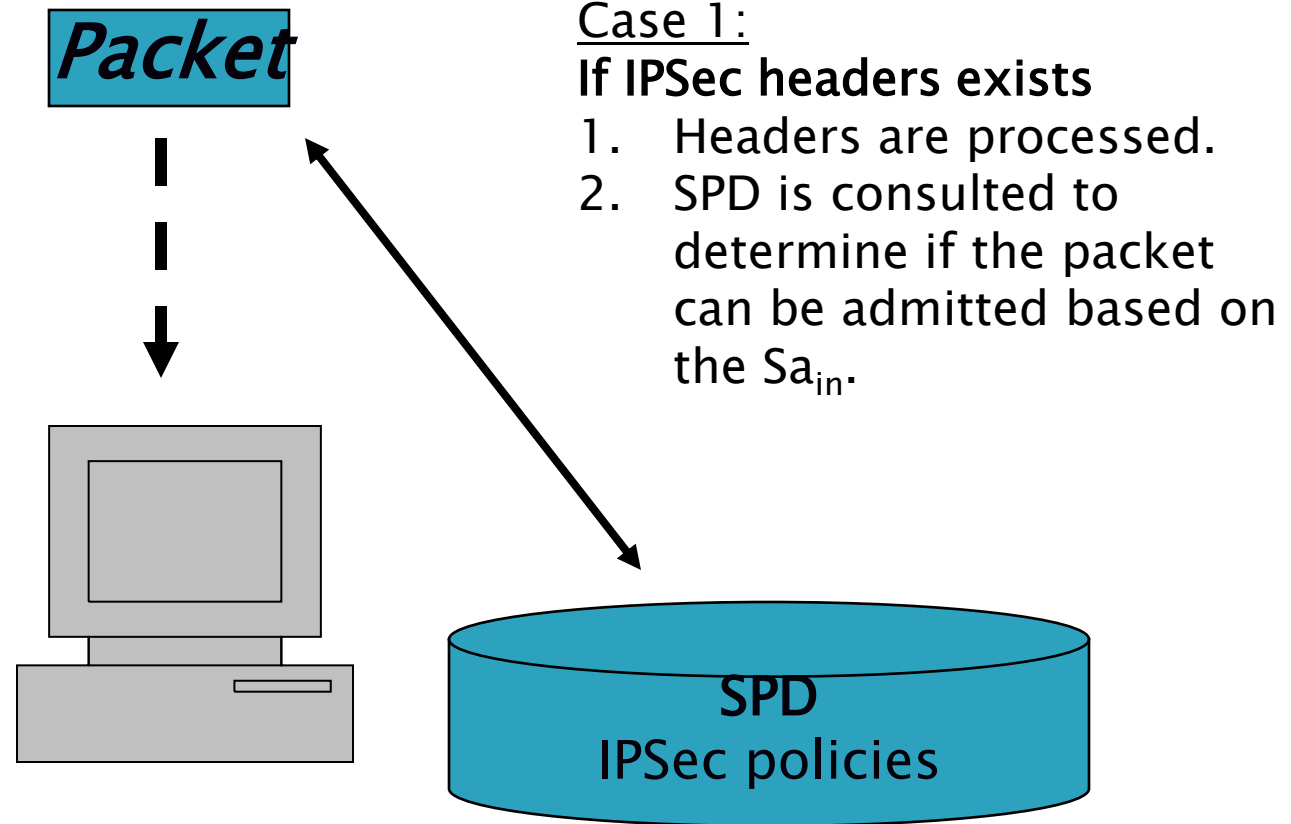
Outbound IPSec Processing



SPD = Security Policy Database
SAD = Security Association Database
SA = Security Association

1. Drop the packet.
2. Bypass IPSec.
3. Apply IPSec.

Inbound IPSec Processing

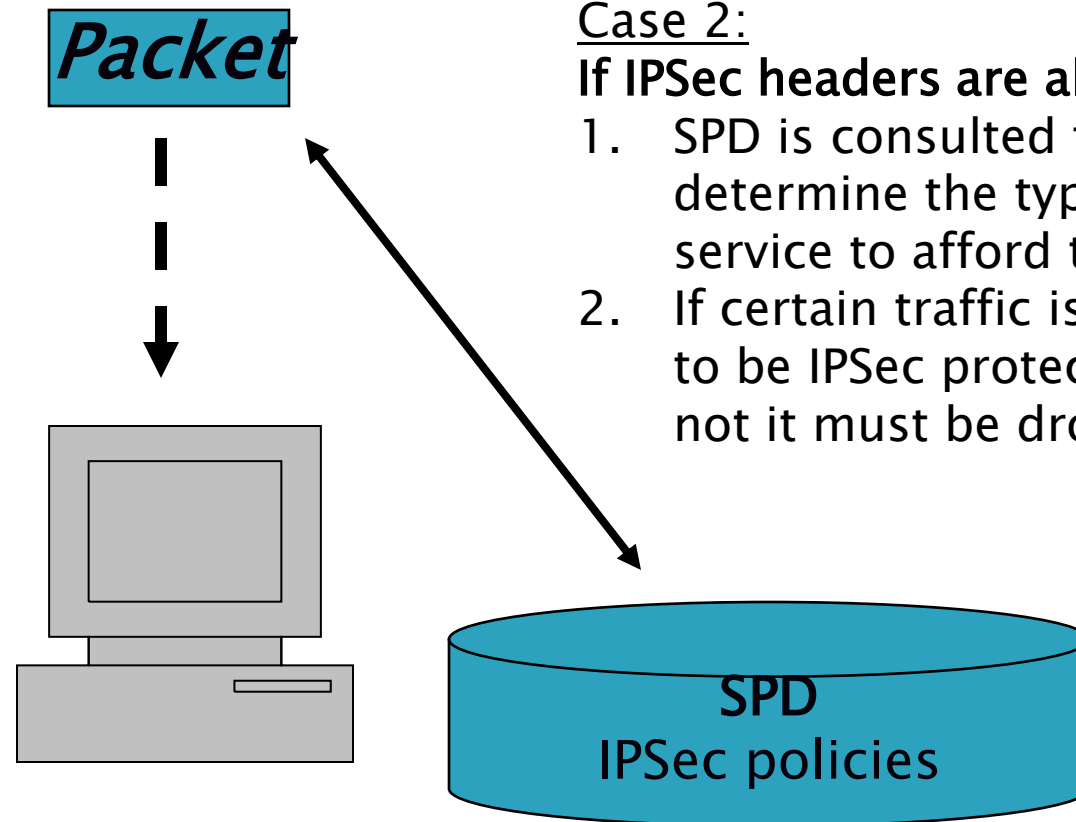


SPD = Security Policy Database

SAD = Security Association Database

SA = Security Association

Inbound IPSec Processing



Case 2:

If IPSec headers are absent

1. SPD is consulted to determine the type of service to afford this packet.
2. If certain traffic is required to be IPSec protected and its not it must be dropped.

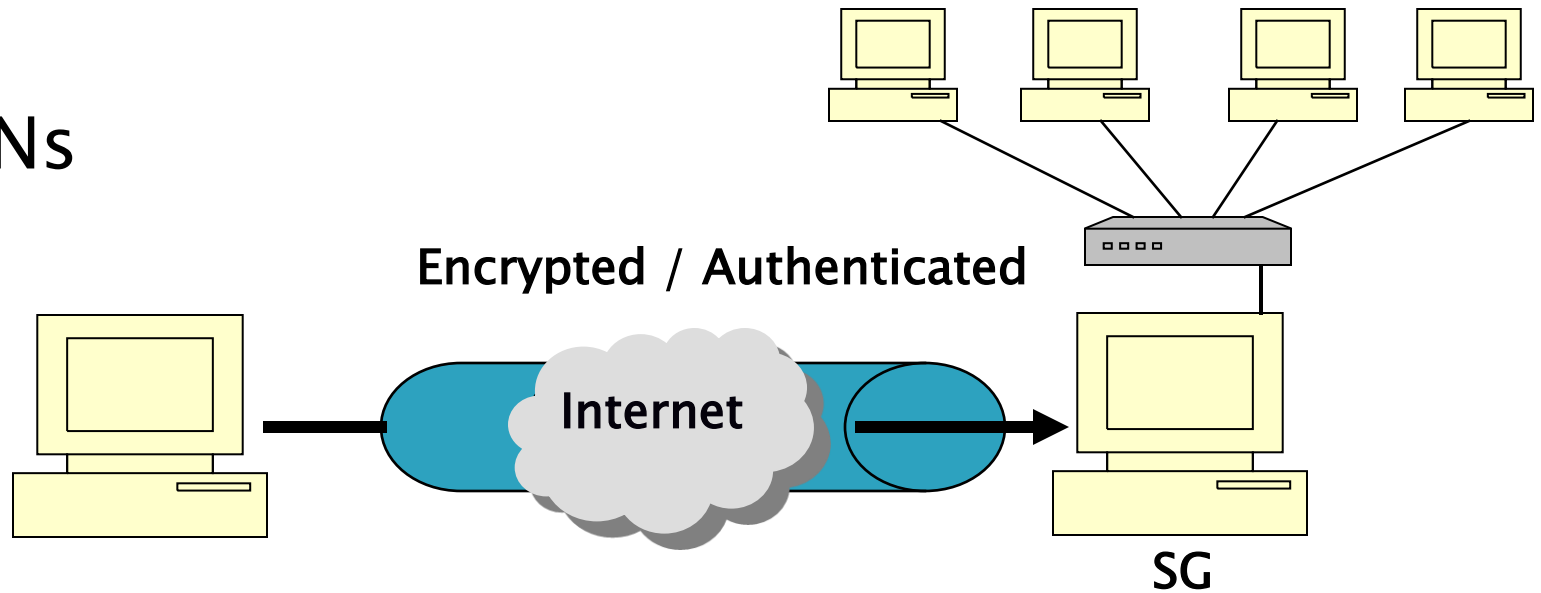
SPD = Security Policy Database

SAD = Security Association Database

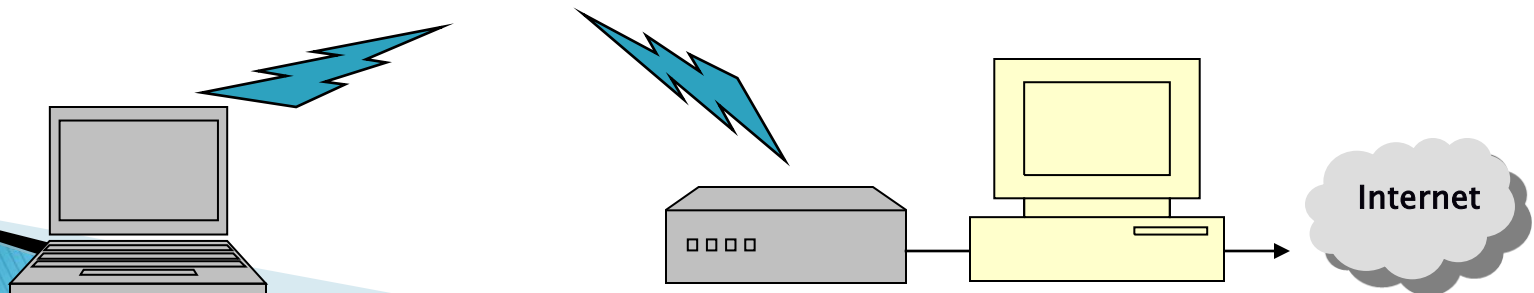
SA = Security Association

Real World Deployment Examples

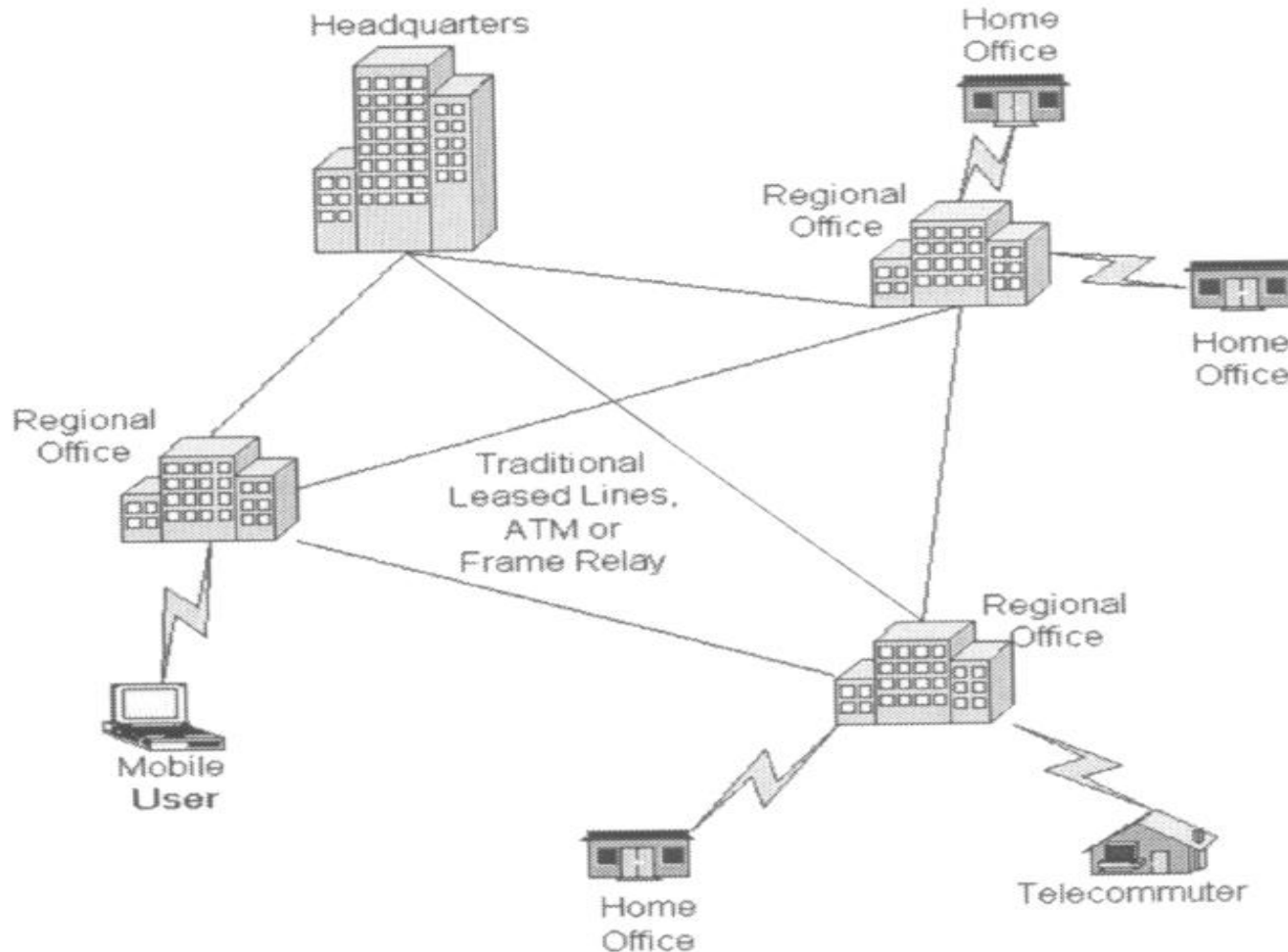
▶ VPNs



▶ Wireless



Traditional Connectivity



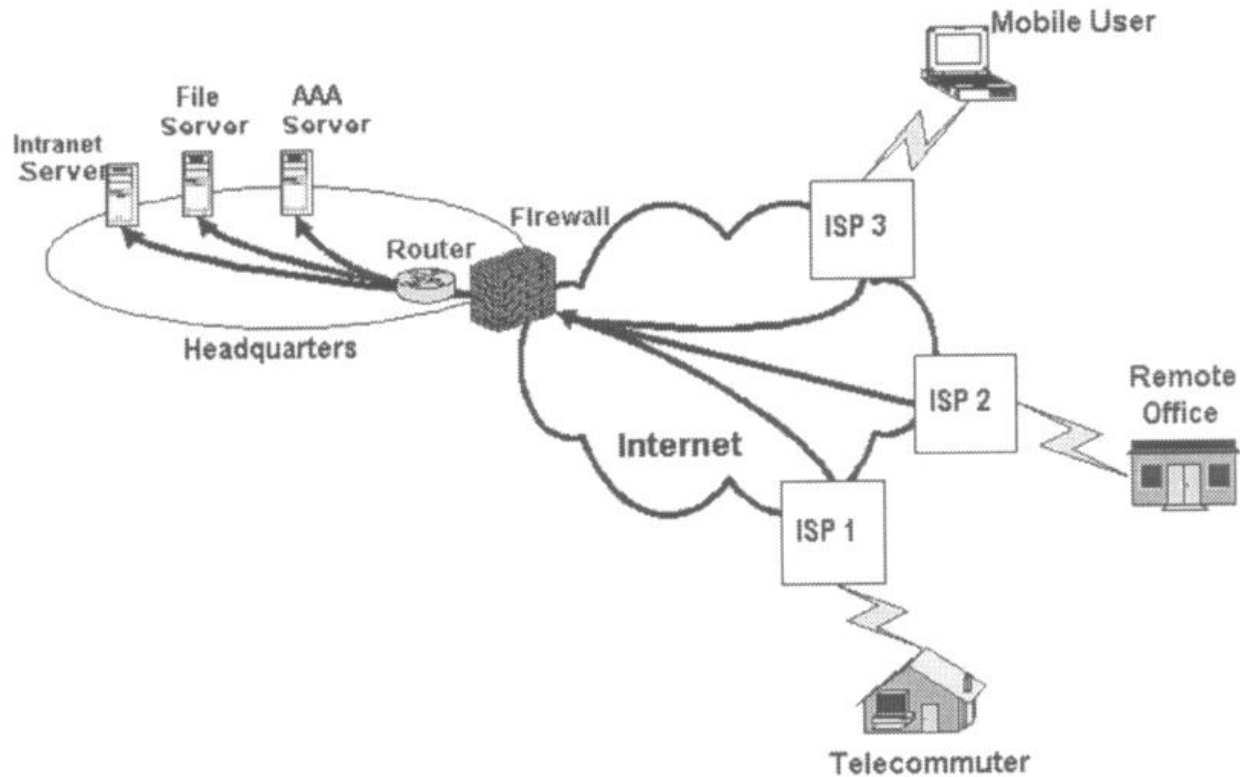
What is VPN?

- Virtual Private Network is a type of private network that uses public telecommunication, such as the Internet, instead of leased lines to communicate.
- Became popular as more employees worked in remote locations.
- Terminologies to understand how VPNs work.

Private Networks vs. Virtual Private Networks

- ★ Employees can access the network (Intranet) from remote locations.
- ★ Secured networks.
- ★ The Internet is used as the backbone for VPNs
- ★ Saves cost tremendously from reduction of equipment and maintenance costs.
- ★ Scalability

Remote Access Virtual Private Network



Brief Overview of How it Works

- ✓ Two connections – one is made to the Internet and the second is made to the VPN.
- ✓ Datagrams – contains data, destination and source information.
- ✓ Firewalls – VPNs allow authorized users to pass through the firewalls.
- ✓ Protocols – protocols create the VPN tunnels.

Four Critical Functions

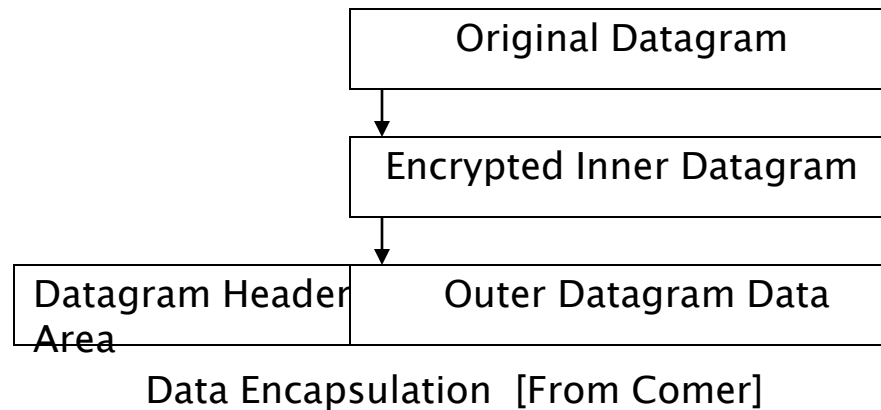
- ❑ Authentication – validates that the data was sent from the sender.
- ❑ Access control – limiting unauthorized users from accessing the network.
- ❑ Confidentiality – preventing the data to be read or copied as the data is being transported.
- ❑ Data Integrity – ensuring that the data has not been altered

Encryption

- ❖ Encryption -- is a method of “scrambling” data before transmitting it onto the Internet.
- ❖ Public Key Encryption Technique
- ❖ Digital signature – for authentication

Tunneling

A virtual point-to-point connection made through a public network. It transports encapsulated datagrams.



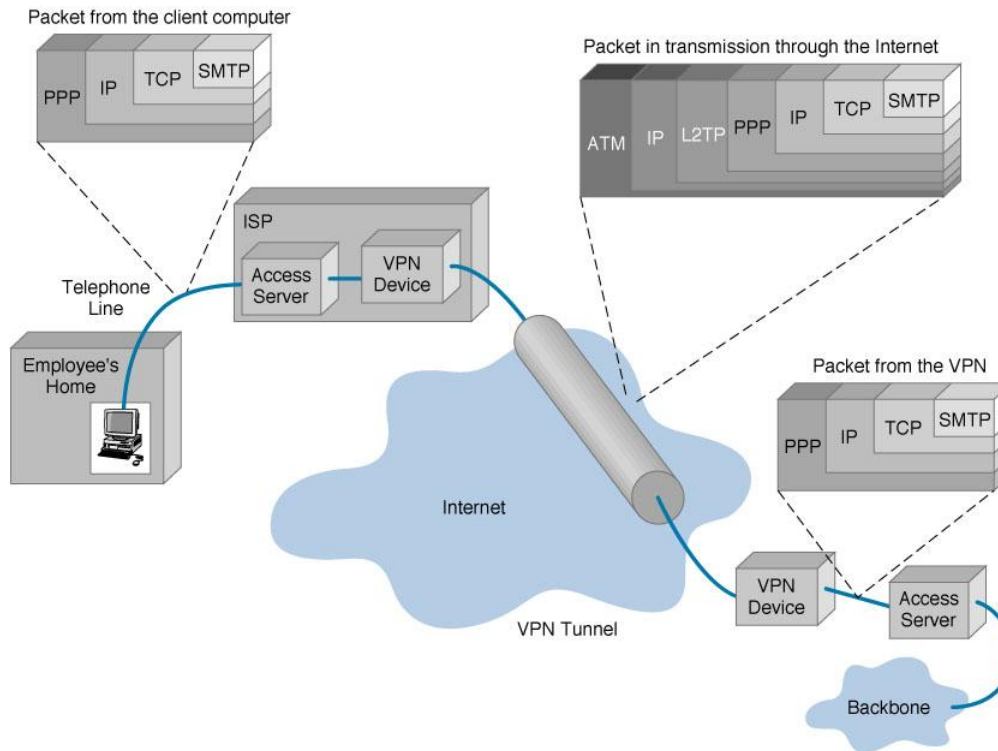
Two types of end points:

- ☐ Remote Access
- ☐ Site-to-Site

Four Protocols used in VPN

- PPTP -- Point-to-Point Tunneling Protocol
- L2TP -- Layer 2 Tunneling Protocol
- IPsec -- Internet Protocol Security
- SOCKS – is not used as much as the ones above

VPN Encapsulation of Packets

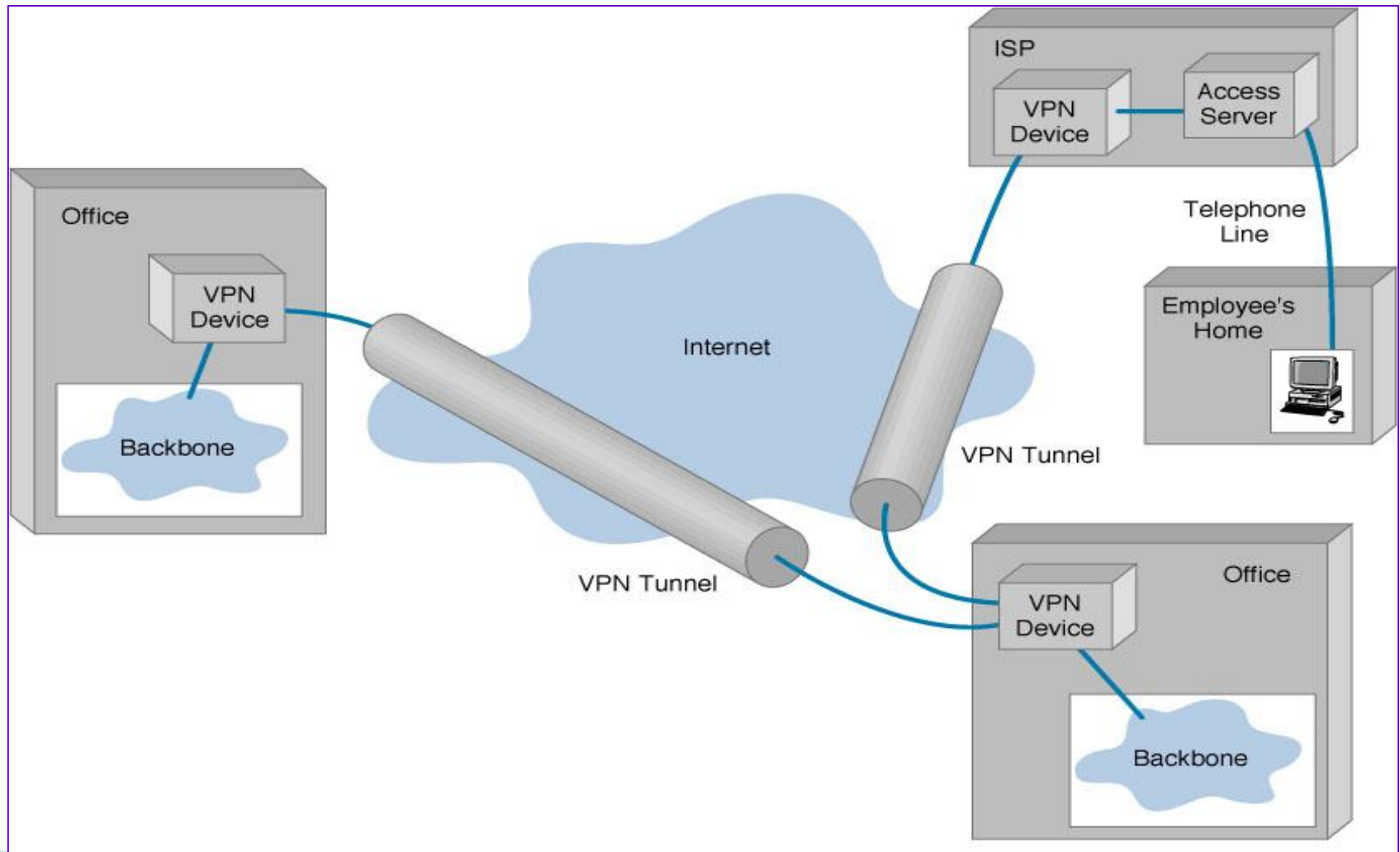


Types of Implementations

- ❑ What does “implementation” mean in VPNs?
- ❑ 3 types
 - ❑ Intranet – Within an organization
 - ❑ Extranet – Outside an organization
 - ❑ Remote Access – Employee to Business

Virtual Private Networks (VPN)

Basic Architecture



Device Types

- ▶ 3 types
 - Hardware
 - Firewall
 - Software

Assignment

1. What is network security? Differentiate network security with computer security.
2. Why network security is needed?
3. Explain the principal methods of protecting network.
4. Explain the components of network organization.
5. Define firewall and explain how firewall protects the network.
6. List the characteristics of firewall. Explain different types of firewall in brief.
7. What do you mean by DMZ? Explain functions of different DMZ servers
8. What is IPSec? Differentiate between IPSec and VPN.